

Nuclei

An upcoming open source DAST tool is Nuclei. It is an application that needs to be downloaded and installed on our local computer.

Using a template, Nuclei is used to deliver queries across targets, producing no false positives and providing rapid scanning on many hosts. Nuclei scans a wide range of protocols, including TCP, DNS, HTTP, SSL, File, Whois, WebSocket, Headless, etc. It enables complex and flexible templating, which may be applied to represent different security checks.

The reference for the nuclei repository is <https://github.com/projectdiscovery/nuclei>.

The security tools covered in this article are efficient and easy to integrate with the development pipeline. Acunetix and Guardrails showcase cutting-edge technologies that are constantly improving due to their intuitive user interfaces, deeper feature sets, quick testing, and enhanced efficiency. In contrast to Guardrails, which is immediately connected to GitHub or other accounts where it is simple to access projects, Acunetix requires installation and a subscription edition for additional

All Scans	Type	Scan	# Vulns	Commit SHA	Actions
Brain-Health-Initiative-Application/main Installation scan triggered via the Dashboard	Branch	05/12/22 - 3:09:21 Finished in: 00:52	22	d510f59d3ec6	
2 Hard-Coded Secrets - Fixing advice for General.					
☐	Severity	Vulnerability Title	Location	Introduced By	Status
☐	● ● ● ●	Secret Keyword	Repo: Brain-Health-Initiative-Application Branch: main File: /src/commo...onstants/ActionConstants.js, Line: 15	GuardRails	! -
☐	● ● ● ●	Secret Keyword	Repo: Brain-Health-Initiative-Application Branch: main File: /src/commo...onstants/ActionConstants.js, Line: 13	GuardRails	! -
1 Insecure Use of Regular Expressions - Fixing advice for JavaScript.					
18 Vulnerable Libraries - Fixing advice for Java, JavaScript.					

Figure 15: Report of an example scan

Severity	Vulnerability Title	Location
● ● ● ●	Secret Keyword	Repo: Brain-Health-Initiative-Application Branch: main File: /src/commo...onstants/ActionConstants.js, Line: 15
<pre> 12 // change password constants 13 export const CHANGE_PASSWORD_REQUEST = "changePasswordRequest" 14 export const CHANGE_PASSWORD_SUCCESS = "changePasswordSuccess" 15 export const CHANGE_PASSWORD_FAILURE = "changePasswordFailure" 16 17 // alert constants 18 export const ALERT_SUCCESS = "alertSuccess" </pre>		

Figure 16: Vulnerability description

References

- DevSecOps: Static Application Security Testing Using Snyk and SonarQube, by Shriya Kabra and B. Thangaraju, *Open Source For You*, January 2021, pp. 69-74
- DevSecOps: Integrating a Dynamic Application Security Testing Tool with Jenkins, by Akhilank M.J. Kaipu and B. Thangaraju, *Open Source For You*, January 2021, pp. 84-88
- Acunetix Web Vulnerability Scanner download, available at <https://acunetix-web-vulnerability-scanner.software.informer.com/download/#downloading>
- GuardRails home page at <https://docs.guardrails.io/docs/what-is-guardrails>

capabilities. Nuclei is also being used frequently and helping to fix security related issues in developed software.

By: Udith Sai M. and Dr B. Thangaraju

The authors are associated with the Open Source Technology Lab in the International Institute of Information Technology, Bengaluru.